Supplementary Material

SecureFlow: The Limits of Content Filtering and the Value of Provenance-Aware, Least-Privilege Enforcement on the Inter-Agent Edge of LLM Pipelines

Piyush Yadav, Pushpita Kundu, Sukanya Mukherjee

1 v1 rule catalog and threshold plateaus

Table 1: The v1 rule catalog (literal-substring matching; every weight is below $\tau = 60$).

Rule	Weight	Patterns	Fired on (of 30)
`prompt_injection`	35	11	6
`privilege_escalation`	40	11	5
`role_confusion`	30	9	6
`data_exfiltration`	30	10	5
`jailbreak_phrases`	45	8	1

Table 2: v1 on the 30-attack corpus: exact threshold plateaus (benign suppressions are 0 of 20 throughout).

Threshold τ	Suppressed / 30	BER
$5 \leq \tau \leq 30$	20	33.3%
$31 \leq \tau \leq 35$	12	60.0%
$36 \leq \tau \leq 40$	7	76.7%
$41 \leq \tau \leq 65$	3	90.0%
$66 \leq \tau \leq 70$	2	93.3%
$71 \leq \tau \leq 75$	1	96.7%
$\tau \geq 76$	0	100.0%

2 v2 rule families and leave-one-rule-out ablation

3 Pooled threshold sweep (v2 rules)

4 Adaptive-adversary results

Operators: synonym substitution, filler insertion, intra-word hyphenation, adjacent-letter typos, and phrase translation (Spanish/French/German), plus depth-2 compositions (budget 1,500 per seed, fixed RNG seed). Operators preserve meaning for a human reader; we did not verify that a target LLM still follows the rewrite.

5 Latency (reference machine)

Table 3: v2 rule families: severity, number of regular expressions, and detections lost when the family is removed (pooled corpus, 93 attacks; the full v2 detects 78; scanning raw lowercased text instead of normalized views detects 71).

Rule family	Severity	Patterns	Detections lost
prompt_injection	70	10	7
jailbreak_phrases	70	9	1
chat_template_tokens	70	3	1
exfil_channel	65	7	4
agent_directed_instruction	60	7	2
privilege_escalation	60	8	7
role_confusion	60	9	4
data_exfiltration	60	10	9
safety_bypass	60	6	6
propagation	60	3	0
destructive_command	55	5	1
destructive_data	55	1	1
defense_evasion	55	2	0
delimiter_spoofing	45	4	0
approval_bypass	45	4	1
mode_switch	40	1	0
authority_claim	40	4	1

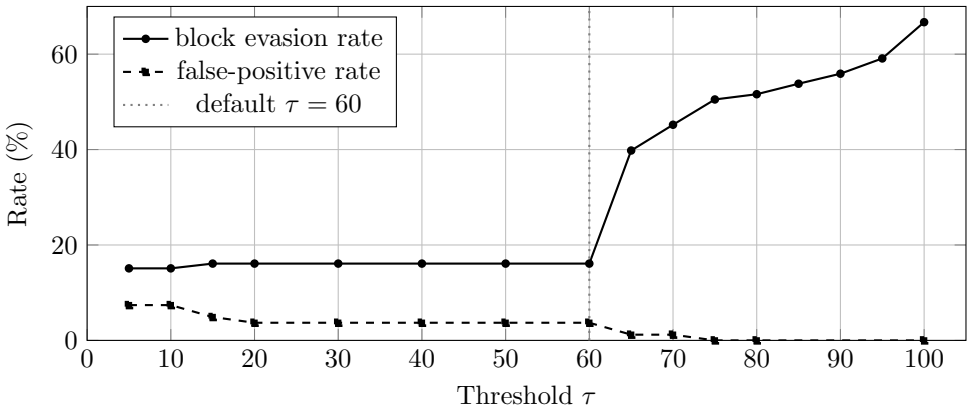


Figure 1: v2 rules on the pooled corpus (93 attacks / 81 benign): BER and FPR against threshold. Zero false positives requires $\tau \geq 75$, where BER is at least 50.5%.

Table 4: Oracle-guided evasion over 93 seeds (95% Wilson CI). "Initially blocked" = seeds the detector blocked before any rewriting. "Text-only holdouts" resist all text operators and evade only via decoder-dependent encodings (base32, reversal, Caesar shift), which are not counted as evasions.

Detector	Initially blocked	Evaded of those	Median queries	Holdouts
v1 keyword (τ=60)	5/93	5/5 = 100% [56.6, 100]	2	0
v2 rules (τ=60)	78/93	70/78 = 89.7% [81.0, 94.7]	68	8
v2, untrusted (τ=40)	78/93	69/78 = 88.5% [79.5, 93.8]	80	9

Table 5: Latency in milliseconds. Intel Core i5-1145G7 (4 cores / 8 threads), 15.7 GB RAM, Windows 11, CPython 3.12.10; `perf_counter_ns`, 300 discarded warm-ups, one thread. Repeated runs varied by up to about 1.5×; use for order of magnitude and the v1–v2 ratio.

Operation	n	**Mean**	**Median**	**p95**	**Max**
v1 scoring, 74 chars	20,000	0.0250	0.0189	0.0430	18.83
v1 scoring, 3 KB	2,000	0.0383	0.0366	0.0493	0.196
v2 scoring, 74 chars	5,000	0.899	0.692	1.93	8.06
v2 scoring, 1 KB	2,000	11.67	10.81	19.38	40.67
v2 scoring, 3 KB	1,000	28.98	26.26	45.76	111.8
v2 intercept + log, 74 chars	3,000	1.894	1.660	3.55	21.85
v2 intercept + log, 3 KB	1,000	42.17	40.49	72.52	139.4
Envelope sign	5,000	0.0350	0.0286	0.0576	0.900
Envelope verify (HMAC + replay)	5,000	0.0301	0.0232	0.0582	0.347
Tool authorize (arg. scan on)	5,000	1.222	1.107	2.19	43.23